Vertiv (Liebert / Avocent / Geist / NetSure) Firmware Attack Surface & Detection Brief

Vertiv (Liebert / Avocent / Geist / NetSure) Firmware Attack Surface & Detection Brief

Scope: 3 products with extracted firmware / ~43,131 unique hashes across 6 architecture classes (Groups D, E, F are research-only — extraction pending). Findings combine CVE research and direct examination of the extracted Avocent ACS 8000 and Liebert IntelliSlot IS-UNITY-DP rootfs (services, default configs, embedded resources); Geist PDU, NetSure DC power, and Vertiv management software entries are CVE/PSIRT research only.

Purdue layer mapping: Avocent ACS 8000 (Group A), IntelliSlot Unity NMC (Group B), and Geist PDU NMCs (Group D) live at **Purdue L3.5 (IT/OT Boundary)** as serial-aggregator and SNMP-bridge devices. Liebert GXT5 UPS MCU (Group C) and NetSure DC power controllers (Group E) sit at the **Power Infrastructure** cross-cut (L0/L1-adjacent — not strictly Purdue L1). Vertiv management software (Group F) runs at **Purdue L3 (Site Operations)**. See purdue-l35-it-ot-boundary-brief.md (includes the Power Infrastructure appendix) and purdue-l3-site-operations-brief.md for cross-vendor views.

Architecture grouping (drives the threat model, not the SKU)

Class	Purdue layer	Products	Stack	Catalog depth
A. Avocent ACS 8000 console server	L3.5 IT/OT Boundary	ACS 8000 (4/8/16/32/48-port)	ARM Linux + busybox + OpenSSH + lighttpd/nginx web UI + serial-port daemons (`portmgr` , `cycladesd`)	34,689 hashes
B. Liebert IntelliSlot Unity NMC	L3.5 IT/OT Boundary	IS-UNITY-DP, IS-UNITY-LIFE, IS-UNITY-SNMP	ARM Linux + ext2 rootfs + busybox + Velocity protocol stack + SNMP/Modbus/BACnet daemons	8,437 hashes
C. Bare-metal UPS MCU	Power Infrastructure (L0/L1-adjacent)	Liebert GXT5 Lithium-Ion UPS	Renesas/STM32 MCU, monolithic firmware blob	5 hashes
D. Geist PDU NMCs	L3.5 IT/OT Boundary (Power Infrastructure outlet-actuation core)	Geist GU/GUL/I03/R-series Upgradeable PDUs	ARM Linux + Lua web UI ("Geist Manager"), SSH/SNMP/Modbus	research only
E. NetSure DC power controllers	Power Infrastructure / L1-adjacent	NetSure 211/501/701/801 (M830B / NCU+ / ACU+ controllers)	ARM Linux + proprietary "ACU" web UI, SNMP/Modbus over -48VDC plant	research only

Class	Purdue layer	Products	Stack	Catalog depth
F. Vertiv management software (Windows/Java)	L3 Site Operations	Vertiv Power Insight, Trellis Platform, Environet Alert, Avocent DSView	Windows .NET / Apache Tomcat / Postgres / Java	research only

---

Group A — Avocent ACS 8000 (highest blast radius — serial console aggregator) — Purdue L3.5 (IT/OT Boundary)

Direct attack surface (verified via `etc/init.d` + `/usr/sbin` in the extracted ACS 8000 rootfs):

```
sshd · lighttpd (HTTPS web UI) · portslave / cycladesd (serial multiplexer) ·
snmpd (v1/v2c/v3) · ipsec (strongSwan) · dhcpd · rsyslogd · radclient (RADIUS/TACACS)
```

The ACS 8000 brokers serial consoles for everything in the rack — routers, PDUs, BMCs, IPMI — so a compromised ACS is a console-level pivot into every device cabled to it. Default config ships with `root` / `admin` accounts and password-auth SSH enabled until first boot.

Confirmed CVEs:

CVE	CVSS	Product	Vector	Status on the firmware you have
CISA ICSA-23-285-06 — Vertiv Avocent ACS 8000	—	ACS 8000 firmware <= 3.3.x	Multiple — OS command injection + auth bypass + hardcoded creds (root)	**verify against your extracted version string in `/etc/version`**
Vertiv PSIRT — ACS 8000 advisories	—	Avocent ACS 8000	Hardcoded credential / insecure default	rootfs cred audit required against `/etc/shadow` and `/etc/passwd`
Nozomi Networks Labs — ACS 8000 research	—	ACS 8000	Chained unauth → root via web UI + serial daemon	research detail for IOCs

Top attack vector (MITRE ATT&CK ICS): T0859 Valid Accounts into the console server, then T0822 External Remote Services — every serial port becomes a remote-access vector into the connected device, bypassing that device's own network ACLs.

Group B — Liebert IntelliSlot IS-UNITY-DP NMC — Purdue L3.5 (IT/OT Boundary)

Direct attack surface (verified in the extracted ext2 rootfs):

```
sshd · lighttpd web UI · snmpd (v1/v2c/v3) · modbusd (TCP/502) ·
bacnetd (UDP/47808) · velocityd (Liebert proprietary protocol, TCP/3211) · telnetd (factory default)
```

The IS-UNITY-DP is the management plane for Liebert UPS, CRAC/CRAH units, and chillers. Factory firmware enables Velocity (Liebert's proprietary monitoring protocol) **and** Modbus TCP **and** BACnet/IP simultaneously. Velocity protocol authentication is community-string-equivalent.

Confirmed CVEs:

CVE	CVSS	Product	Vector	Status on the firmware you have
CISA ICSA-22-167-15 — Vertiv Liebert IS-UNITY	—	Vertiv Liebert IS-UNITY	Use of hard-coded credentials + insufficiently protected creds	verify firmware version, check `/etc/shadow` and `/etc/passwd` in your rootfs
Vertiv PSIRT — Liebert IntelliSlot Unity	—	IS-UNITY-DP / LIFE / SNMP	Default/hardcoded credentials	applies to factory-default IS-UNITY firmware
Claroty Team82 — Velocity/OT protocol research	—	Velocity (Liebert)	Unauthenticated UPS/cooling command issuance	applies to all factory-default IS-UNITY

Top attack vector (MITRE ATT&CK ICS): T0836 Modify Parameter via SNMP `Set` or Velocity write — attacker disables cooling, forces UPS battery test, or changes alarm thresholds to mask physical attacks. The 2022 CISA UPS advisory called out internet-exposed UPS NMCs running default Liebert/APC creds.

Group C — Liebert GXT5 Lithium-Ion UPS (bare-metal MCU) — Power Infrastructure (L0/L1-adjacent)

Only 5 hashes — a monolithic MCU firmware blob with no network surface on the UPS itself; it reaches the network only via an attached IS-UNITY NMC.

Attack vectors:

1. **Serial/USB console** (RJ45 EIA-232 + USB-B) — direct register access if attacker has rack access
2. **Firmware tamper via the IS-UNITY card's "UPS firmware update" passthrough** — the high-value path
3. **Battery-management parameter abuse on the Li-Ion chemistry** — thermal-runaway risk if BMS protection thresholds (cell voltage limits, temperature shutoff) are altered. This is the GXT5-Lithium-specific risk the standard VRLA GXT line does not have.

Top vector: Compromise the IS-UNITY NMC, then push tampered MCU firmware. Vertiv does not publish per-block SHA256 manifests the way Eaton does — you cannot verify a flash from outside the device.

Group D — Geist PDU NMCs (research only — extraction pending) — Purdue L3.5 (IT/OT Boundary) with Power Infrastructure outlet-actuation core

Direct attack surface (per vendor documentation): SSH, SNMP v1/v2c/v3, HTTP/HTTPS web UI ("Geist Manager"), Modbus TCP, optional BACnet/IP, EnergyWise. Default credentials historically `admin` / `admin`.

Confirmed CVEs:

CVE	CVSS	Product	Vector	Status
CISA ICSA-22-242-15 — Vertiv Geist Rack PDU	—	Vertiv Geist Rack PDU	Multiple — weak session mgmt, XSS, info disclosure	research only
Vertiv PSIRT — Geist Upgradeable PDU	—	Geist Upgradeable PDU	Authenticated path traversal / file read	research only

Top vector: T0812 Default Credentials — Geist PDUs have a long history of internet exposure on TCP/443 with factory creds.

Group E — NetSure DC power (research only — extraction pending) — Power Infrastructure / L1-adjacent

NetSure controllers (M830B / NCU+ / ACU+) sit on -48VDC telecom plants and central offices. Vendor-documented services: SSH, HTTP/HTTPS, SNMP v1/v2c/v3, Modbus TCP, YDN23 (China telecom protocol). CISA ICSA-22-242-15 covered the M830B controller for hard-coded credentials and improper auth.

Top vector: T0822 External Remote Services — NetSure is often the only thing keeping the central-office DC plant up; loss-of-view or rectifier shutdown is a direct telecom outage primitive.

Group F — Vertiv management software (the Windows/Java surface) — Purdue L3 (Site Operations)

CVE	CVSS	Product	Vector
Vertiv PSIRT — Avocent DSView advisories	—	Vertiv Avocent DSView	Pre-auth deserialization / RCE (per vendor advisory)
Synopsys CyRC — Avocent / HPE KVM advisory	—	Avocent KVM family (shared firmware)	Hardcoded creds + buffer overflow (unauth → root)
CVE-2021-44228 — Apache Log4j (Log4Shell)	10.0	Trellis 5.x (Tomcat) — if unpatched	Classic Log4j JNDI RCE

If your admin hosts run DSView or Trellis, those are the foothold paths to every Avocent/Liebert device underneath them.

Logging matrix (highest priority)

Top 8 — ordered by detection value per ingest dollar:

#	Source	Event	What it catches	MITRE ATT&CK ICS
1	**ACS 8000 syslog (UDP/514)**	`portmgr` session open from non-admin VLAN	Attacker reaching serial consoles	T0822 External Remote Services
2	ACS 8000 syslog	`firmware_upgrade.start` / `bootloader.write`	Firmware tamper on the pivot device	T0857 System Firmware
3	IS-UNITY syslog	`velocity.command.write` to UPS/CRAC parameters	Cooling / UPS control tamper	T0836 Modify Parameter
4	**Network IDS (Suricata/Zeek)**	SNMP `Set-Request` to UPS/PDU/CRAC NMCs from outside management VLAN	Direct exploitation	T0836 Modify Parameter
5	Network IDS	**Modbus FC 5/6/15/16** crossing management→OT boundary toward Liebert/Geist IPs	Control-logic tamper	T0833 Modify Control Logic
6	Network IDS	BACnet `WriteProperty` to IS-UNITY or CRAC IPs	Building-automation pivot	T0836 Modify Parameter
7	**Sysmon on DSView/Trellis hosts**	EventID 1 (ProcessCreate) where ParentImage= `tomcat*.exe` AND child= `cmd.exe` / `powershell.exe` / `bash.exe`	DSView deserialization / Log4Shell-class post-exploit	T1059 (Enterprise)
8	ACS 8000 syslog	`login.success` for `root` from any IP **plus** any subsequent `portmgr` activity	Confirmed compromise of console aggregator	T0859 Valid Accounts

Secondary:

- Firewall: any egress from UPS/PDU/CRAC VLANs to non-RFC1918 (NMCs and ACS 8000 should never originate outbound to internet — same CISA 2022 warning that applied to Eaton).
- SNMP trap collector: subscribe to `lgpEnvStateSystemOn`, `lgpEnvTemperatureThresholdAlarm`, `lgpEnvAirflowAlarm`, `epduOutletStateChange`. Correlate cooling alarms with after-hours config changes — masking physical attacks via thermal manipulation is a known TTP.
- Vertiv-native audit: ACS 8000 has built-in audit logging at **System → Logging → Data Buffering + Auditing**; IS-UNITY at **Configuration → System → Event Log**. Both syslog out via UDP/514.
- OT-native power/process anomalies: sudden CRAC fan-speed drop, UPS forced battery-test outside maintenance window, PDU outlet-off events with no ticket — classic pre-incident signals.

Specific zero-day-ish concerns for your dataset

1. **ACS 8000 is a serial-console aggregator — the blast radius is every cabled device.** With 34,689 hashes extracted, audit `/etc/init.d/portslave` and the `cycladesd` binary for command-injection sinks of the class called out by CISA ICSA-23-285-06. Even patched firmware revisions have repeatedly regressed this bug class.

2. **IS-UNITY-DP ships Velocity + Modbus + BACnet enabled by default and Velocity auth is community-string-equivalent.** Audit `/etc/velocity.conf` (or vendor-equivalent) in your extracted ext2 rootfs to confirm whether your unit was hardened before deployment. If `/etc/shadow` matches the hardcoded hash family called out in CISA ICSA-22-167-15, treat every IS-UNITY in the environment as compromised-by-default.

3. **GXT5 Lithium-Ion BMS thresholds — no firmware-signing manifest published.** Unlike Eaton's `.sta` manifest model, Vertiv does not give you per-block SHA256s to compare during a flash. A tampered GXT5 firmware that disables cell-temperature shutoff is undetectable from outside the UPS and is a credible thermal-runaway path on Li-Ion.

4. **DSView / Trellis are unpatched on most sites.** Per the Vertiv PSIRT DSView advisories, pre-auth deserialization gives RCE on the box that holds credentials to every Avocent KVM and ACS in the estate — single point of catastrophic compromise.

Sources

- CISA — Mitigating Attacks Against UPS Devices (2022)
- Vertiv PSIRT / security advisory index
- CISA ICSA-23-285-06 — Vertiv Avocent ACS 8000
- CISA ICSA-22-167-15 — Vertiv Liebert IS-UNITY
- CISA ICSA-22-242-15 — Vertiv Geist Rack PDU / NetSure controllers
- CVE-2021-44228 — Apache Log4j (Log4Shell)
- Claroty Team82 research blog (Velocity / OT protocol research)
- Nozomi Networks Labs — Avocent ACS 8000 research
- Synopsys CyRC — Avocent KVM security research
- MITRE ATT&CK for ICS — External Remote Services (T0822)
- MITRE ATT&CK for ICS — Valid Accounts (T0859)
- MITRE ATT&CK for ICS — Default Credentials (T0812)
- MITRE ATT&CK for ICS — Modify Parameter (T0836)
- MITRE ATT&CK for ICS — Modify Control Logic (T0833)
- MITRE ATT&CK for ICS — System Firmware (T0857)
- CISA/NSA/FBI/ASD — Best Practices for Event Logging and Threat Detection (2024)
- Forescout 2025 OT Threat Report — BACnet now 3rd-most-targeted protocol

---

Apex, Inc. (OUI 00:02:99) — reclassified into this brief, 2026-10-26

The ARNG census lists **39 OT devices in 9 states under "Apex, Inc."** A dedicated-brief research pass resolved that OUI to the **Avocent lineage this brief already covers**: Apex PC Solutions / Apex Inc. (Redmond WA) merged with Cybex in July 2000 to form **Avocent**, which became Emerson Network Power and then **Vertiv**. So "Apex" devices are legacy KVM / serial console-switch hardware in the Avocent/Vertiv family — the same console-server class this brief flags as a Volt Typhoon target. They are folded here rather than given a standalone brief, as Andover/Square D were folded into Schneider.

CVE caution — deliberately not asserted as applicable. Research surfaced real Avocent/Vertiv CVEs (e.g. CVE-2019-9507 on a *current* Vertiv Avocent management appliance; CVE-2013-6030 / CVE-2013-0526 on Emerson-era KVM-over-IP). Their IDs are genuine, but the 39 census devices carry a **~2000-era Apex OUI** and are almost certainly discontinued KVM switches that predate those products. Mapping a 2019 appliance CVE onto 25-year-old hardware would be misattribution, so no CVE is claimed against these specific devices here — the actionable step is to physically identify what the 39 endpoints are before assigning any advisory.